

【中间件安全】IIS6安全加固规范 - 微信公众号Bypass

1. 适用情况

适用于使用IIS6进行部署的Web网站。

2. 技能要求

熟悉IIS配置操作，能够利用IIS进行建站，并能针对站点使用IIS进行安全加固。

3. 前置条件

1、根据站点开放端口、进程ID、确认站点采用IIS进行部署；

2、启用IIS

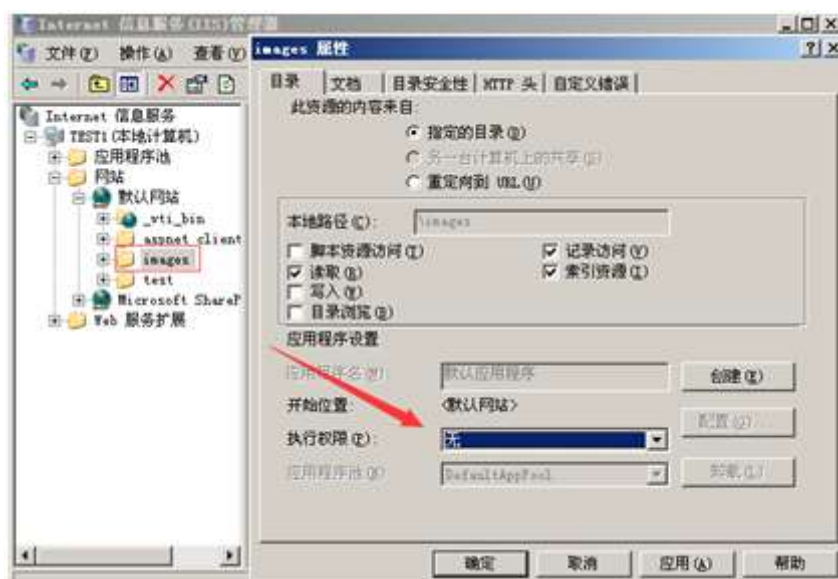
方法一：按Win键+R打开Windows运行，输入inetmgr,回车即可打开；

方法二：开始->管理工具->Internet 信息服务(IIS)管理器。

4. 详细操作

4.1 限制目录执行权限

右键网站目录，对网站用户对目录的权限进行必要的限制，常用于对图片目录、上传目录进行脚本执行权限限制。



4.2 开启日志审计

打开IIS管理工具，右击要管理的站点，选择“属性”。在“网站”选择“启用日志记录”。

PS：IIS默认采用的W3C日志格式采用的是UTC时间，系统时间与UTC的时差为8，也就是UTC+8。



默认情况下Web日志存放于系统目录"%systemroot%/system32/LogFiles"，将Wb日志文件放在非网站目录和非操作系统分区，并定期对Web日志进行异地备份。

点击网站-右键属性-选择网站选项卡-点击属性 如下图：



4.3 自定义404错误页面

点击网站-右键属性-选择自定义错误选项卡出现如下图：



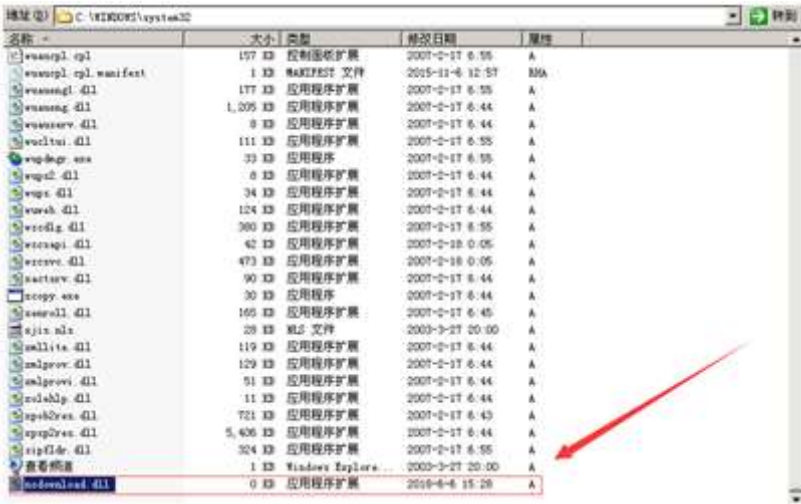
4.4 最佳经验实践

因IIS配置不当，可能导致的安全问题，常见安全漏洞如：WebDAV、目录浏览、FTP匿名访问、IIS短文件名信息泄露、mdb数据库被下载、后台对外开放等。

4.4.1 防止.mdb数据库文件被下载

很多网站都是使用的是asp+access数据库，mdb路径可能被猜解，数据库很容易就被别人下载了，利用IIS设置可有效防止mdb数据库被下载。

步骤一：新建一记事本文件，里面不要填写任何内容，将文件名改为nodownload.dll，拷贝到 C:\Windows\System32\



步骤二：打开IIS服务管理器，选择需要设置的站点，点击右键，选择“属性”，打开站点属性对话框，切换到“主目录”选项卡，点击中下方的“配置”按钮



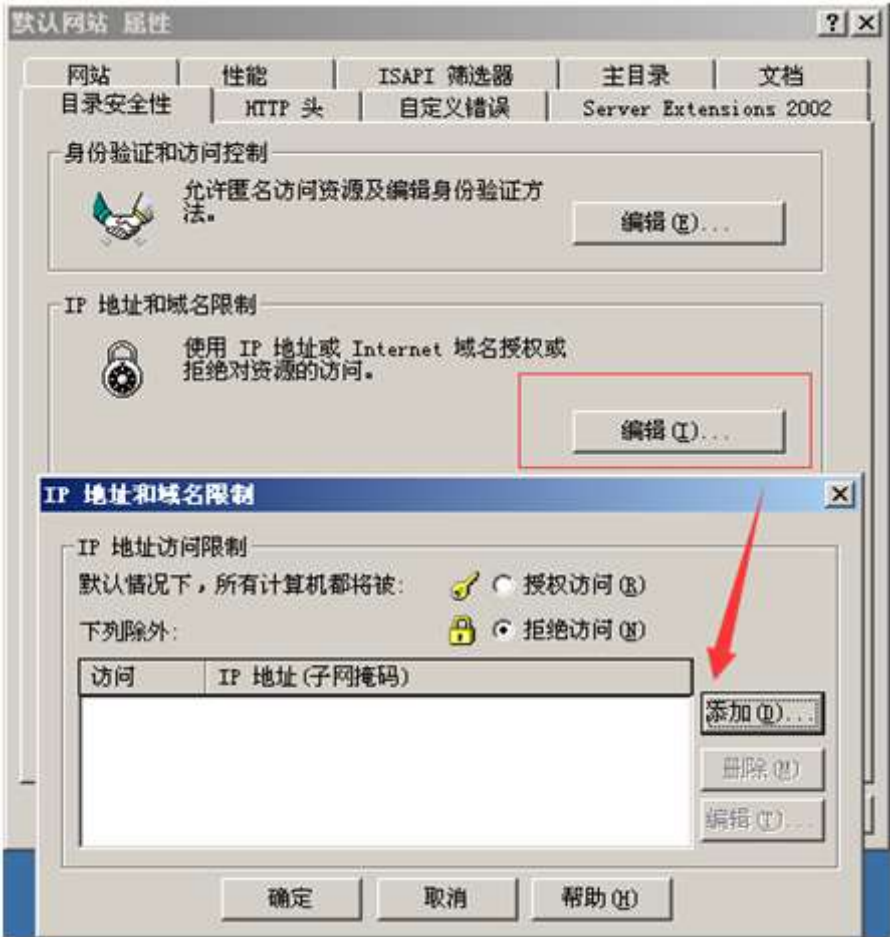
步骤三：弹出应用程序配置窗口，在“映射”选项卡中点击下方的“添加”按钮，弹出添加/编辑应用程序扩展名映射窗口，点击“浏览”按钮，找到刚才那个nodownload.dll文件，“扩展名”文本框中输入“.mdb”，动作设为：全部动作，点“确定”保存设置。



4.4.2 访问源IP限制

在条件允许的条件下，对IIS访问源进行IP范围限制。只有在允许的IP范围内的主机才可以访问WWW服务。常用于限制网站管理后台对外开放。

开始->管理工具->Internet 信息服务(IIS)管理器 选择相应的站点目录，然后右键点击“属性”->目录安全性->IP地址和域名限制->添加允许访问的IP地址。



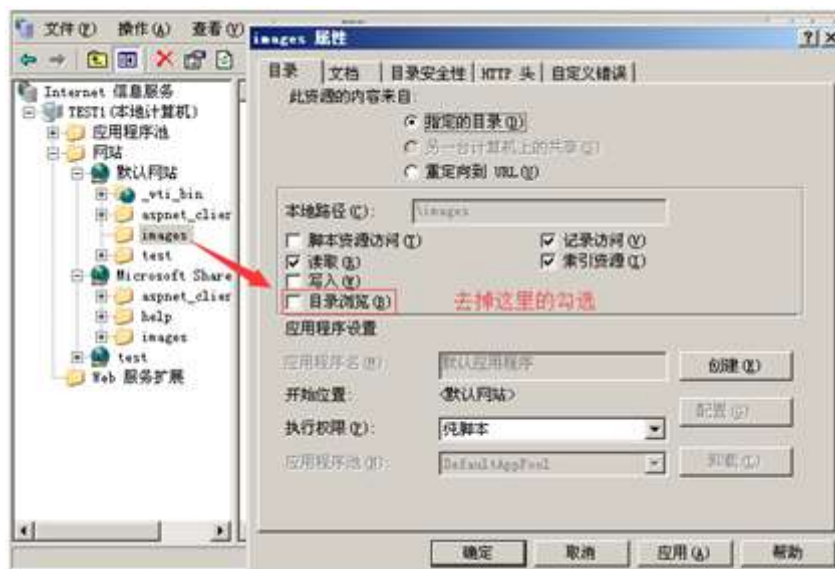
4.4.3 关闭WebDAV

开始->管理工具->Internet 信息服务(IIS)管理器 选择Web服务扩展->WebDAV，然后右键点击“禁止”，确认选择是，关闭WebDAV。



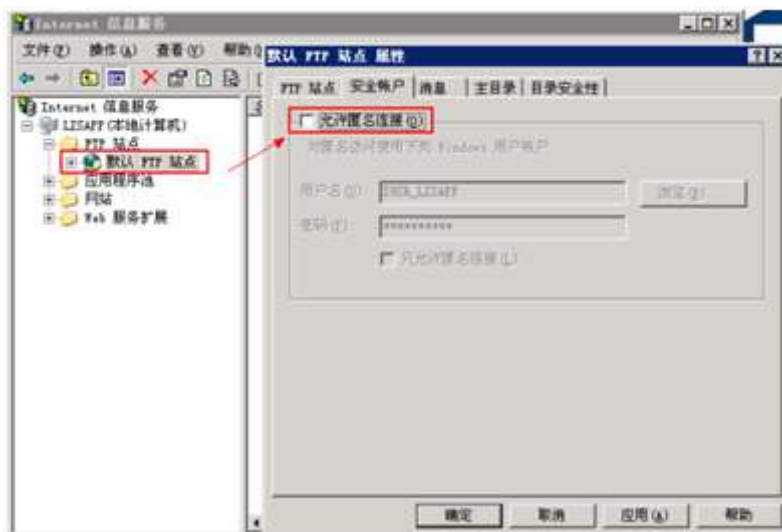
4.4.4 关闭目录浏览

1、 开始->管理工具->Internet 信息服务(IIS)管理器 选择相应的站点目录，然后右键点击“属性”->目录浏览->去掉勾选



4.4.5 关闭FTP匿名访问

1、开始->管理工具->Internet 信息服务(IIS)管理器 选择FTP站点，然后右键点击“属性” ->安全账户->去掉允许匿名连接。



4.4.6 解决IIS短文件名漏洞

利用URLScan工具过滤URL中的特殊字符（仅针对IIS6）-- 解决IIS短文件名漏洞

- 1、 URLScan 3.1下载地址：<http://www.iis.net/downloads/microsoft/urlscan>
- 2、 看系统位数选择安装程序（32或64位），双击运行urlscan程序



3、安装完成以后，我们可以在System32/InetSrv/URLScan目录下找到以下文件：

log：日志目录，开启日志记录功能，会在此目录下生成日志文件； urlscan.dll：动态连接库文件；

urlscan.ini：软件配置文件，这个文件很只要，因为对URLScan的所有配置，均有这个文件来完成。



4、IIS管理--网站（右击属性）---ISAPI筛选器--点击添加--输入筛选器名称和可执行文件--点击确定即可。



5、在UrlScan.ini中进行安全设置，

A、以下两个选项需要设置为一，防止因编码、特殊文件夹导致的系统故障：

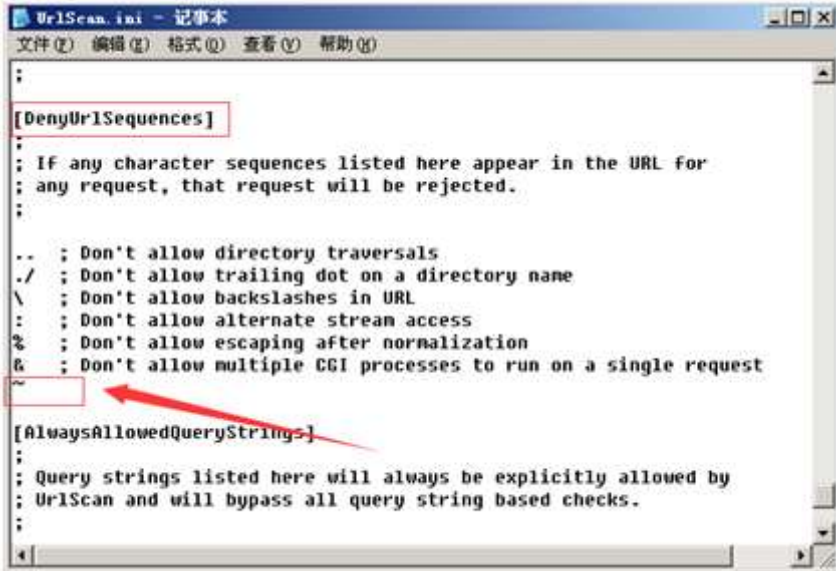
[options]节点中

AllowHighBitCharacters=1 ;default is 0

AllowDotInPath=1 ;default is 0

B、修复IIS短文件名漏洞：

[DenyUrlSequences]节点中新增波浪号



4.5 风险操作项

4.5.1 停用或删除默认站点

1、IIS安装后的默认主目录是“c:\inetpub\wwwroot”，为更好地抵抗踩点、刺探等攻击行为，应该更改主目录位置，禁用默认站点，新建立站点并进行安全配置。

开始->管理工具->Internet 信息服务(IIS)管理器 选择相应的站点，然后右键站点，选择停止或者删除。



4.5.2 删除不必要的脚本映射

1、打开IIS服务管理器，选择需要设置的站点，点击右键，选择“属性”，打开站点属性对话框，切换到“主目录”选项卡，点击中下方的“配置”按钮，从列表中删除以下不必要的脚本，包括 .asa .cer .cdx .idq .htw .ida .shtml .stm .idc .htr .printer等。

删除的原则：只保留需要的脚本映射。



根据需要可以在已经存在的脚本上点击右键进行编辑和删除，也可以自定义添加映射。

4.5.3 设置最大并发连接数

1、打开IIS服务管理器，选择需要设置的站点，点击右键，选择“属性”，打开站点属性对话框，切换到“性能”选项卡，点击中下方的“网站连接”中，设置连接限制。



4.5.4 独立站点帐户

在Windows server 2003系统下，用IIS架设Web服务器，合理的为每个站点配置独立的Internet来宾账号，这样可以限制Internet 来宾账号的访问权限，只允许其可以读取和执行运行网站所需要的程序。

1. 选中“我的电脑”右键，选择“管理”，打开“计算机管理”，选择“本地用户和组”，然后点击“用户”，接着“右键”，新建一个用户，如下图：

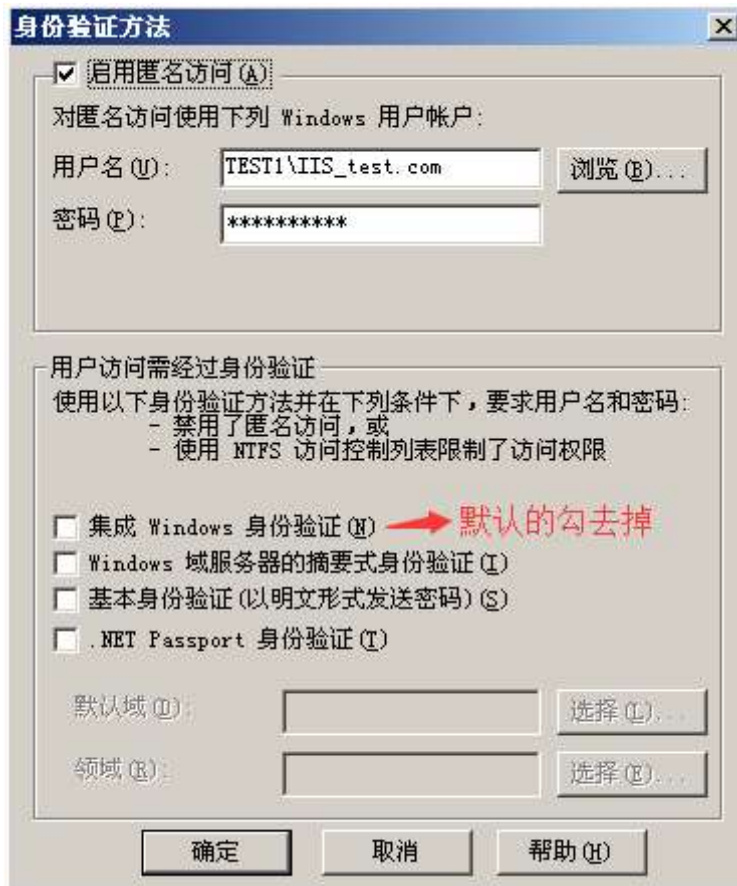
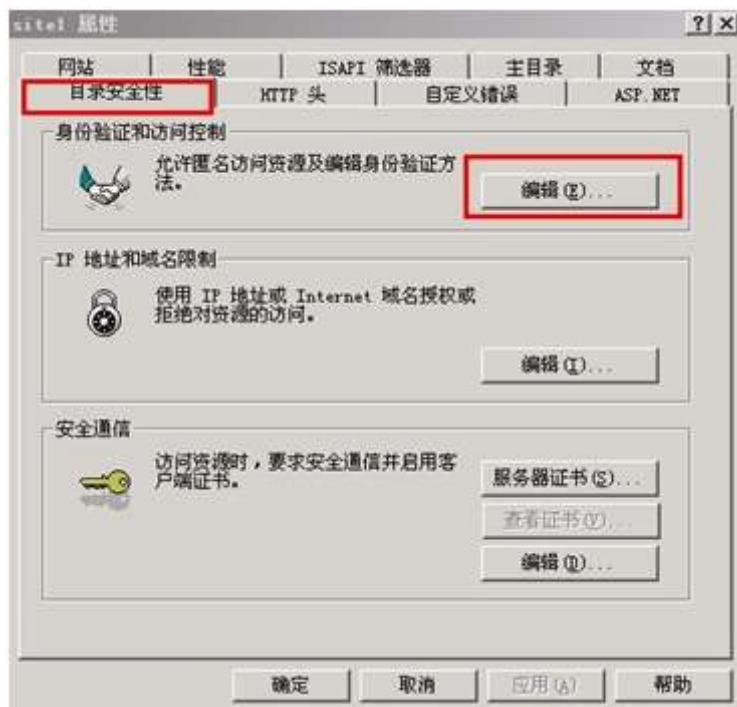


最后点击“创建”，完成用户创建。

2. 删除新建的用户属的用户组“USERS”，然后点击“添加”，让用户属于Guests组，如下图：

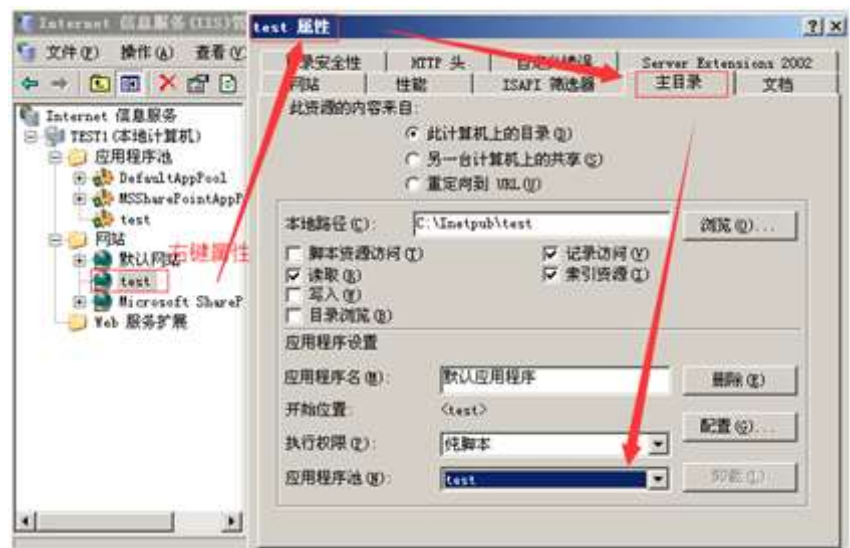
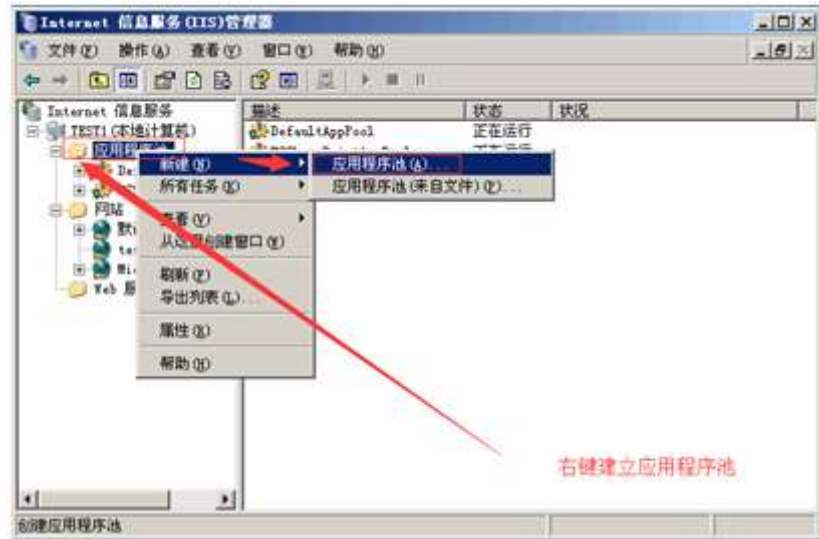


3. 网站设置独立运行用户，加强网站安全



4.5.5 独立应用程序池

给网站设置独立运行的程序池，这样每个网站与错误就不会互相影响：



最后

欢迎关注个人微信公众号: Bypass--，每周原创一篇技术干货。



posted @ 2018-12-24 09:28 [Bypass](#) 阅读(...) 评论(...) [编辑](#) [收藏](#)